

# GRC

## Gouvernance, Risque & Conformité

---

Le manuel complet pour **comprendre en profondeur** et **maîtriser durablement** les notions de GRC : concepts, méthodes, normes, schémas et cas pratiques corrigés.

### Gouvernance

Diriger, décider, responsabiliser, aligner la sécurité sur les objectifs de l'organisation.

### Risque

Identifier, analyser, prioriser et traiter l'incertitude qui pèse sur ces objectifs.

### Conformité

Respecter lois, normes et engagements, et le prouver de façon opposable.

# Comment lire ce manuel

Le GRC n'est pas une liste de définitions à empiler : c'est un **système de raisonnement**. L'objectif de ce manuel n'est pas que tu retiennes des mots, mais que tu comprennes **comment les trois piliers s'articulent** et pourquoi chaque notion existe. Suis cet ordre :

- 1 Lis la Partie 0 en entier d'abord.** Elle donne la vue d'ensemble et la logique qui relie tout le reste. Sans elle, les parties suivantes ressemblent à des listes ; avec elle, elles prennent sens.
- 2 Pour chaque partie, comprends le « pourquoi » avant le « quoi ».** Chaque section commence par l'intuition, puis descend dans le détail. Les encadrés **Définition** posent le socle, les encadrés **Approfondissement** vont plus loin.
- 3 Étudie les schémas.** Un processus se retient mieux visuellement qu'en texte. Redessine-les de mémoire : si tu sais reproduire la boucle GRC, le cycle du risque et la défense en profondeur, tu as compris l'essentiel.
- 4 Fais les cas pratiques (Partie 7) sans regarder le corrigé.** C'est en appliquant que l'on maîtrise. Les points de confusion fréquents (Partie 6) t'évitent les erreurs classiques.
- 5 Reviens à la synthèse (Partie 6).** Une fois le détail vu, la carte mentale et le fil rouge te permettent de tout relier et de vérifier que rien ne « flotte » isolément.

## LE PRINCIPE DIRECTEUR DU MANUEL

Retiens une seule phrase et tout s'y rattache : **la gouvernance fixe le cap et les responsabilités, l'analyse de risque décide où mettre l'effort, la conformité garantit un socle minimal opposable — et les trois se corrigent mutuellement en boucle.** Chaque notion de ce manuel est une pièce de cette mécanique.

# Sommaire

---

|                                                      |    |
|------------------------------------------------------|----|
| <b>0 · Comprendre le GRC : la logique d'ensemble</b> | 4  |
| <b>1 · Gouvernance : diriger et responsabiliser</b>  | 7  |
| Nature de la gouvernance, gouvernance vs management  | 7  |
| Structure organisationnelle & rôles                  | 8  |
| Hiérarchie documentaire & principes fondateurs       | 9  |
| Culture, maturité et pilotage par la mesure          | 11 |
| <b>2 · Risque : maîtriser l'incertitude</b>          | 13 |
| Vocabulaire et anatomie d'un risque                  | 13 |
| Le processus de gestion des risques (ISO 31000)      | 13 |
| Mesurer le risque : qualitatif & quantitatif         | 14 |
| Les méthodes : EBIOS RM, ISO 27005, NIST, FAIR       | 15 |
| Traiter le risque, résiduel, appétence, registre     | 17 |
| Risque tiers & chaîne d'approvisionnement            | 18 |
| <b>3 · Conformité : le socle opposable</b>           | 19 |
| Nature, distinctions, audit et contrôles             | 19 |
| <b>4 · Normes, frameworks &amp; réglementations</b>  | 22 |
| ISO/IEC 27001 & la famille 2700x                     | 22 |
| NIST CSF 2.0, 800-53, COBIT, CIS, COSO               | 23 |
| RGPD, CNIL, NIS2, DORA, ANSSI                        | 24 |
| PCI-DSS, SOC 2, HIPAA, SOX & comparatif              | 27 |
| <b>5 · Concepts transversaux indispensables</b>      | 28 |
| <b>6 · Synthèse : relier toutes les notions</b>      | 31 |
| <b>7 · Cas pratiques &amp; exercices corrigés</b>    | 33 |
| <b>8 · Glossaire &amp; pour aller plus loin</b>      | 36 |

# 0 Comprendre le GRC : la logique d'ensemble

Avant toute définition, saisis l'intuition. Une organisation existe pour atteindre des **objectifs** (soigner des patients, vendre un logiciel, rendre un service public). Trois questions menacent en permanence ces objectifs : *Qui décide et selon quelles règles ? Qu'est-ce qui peut mal tourner ? Respectons-nous nos obligations ?* Le GRC est simplement la discipline qui répond à ces trois questions **de manière coordonnée**.

## DÉFINITION — GRC

Le **GRC (Governance, Risk & Compliance)** est une approche **intégrée** qui permet à une organisation d'atteindre ses objectifs de façon fiable (**gouvernance**), en maîtrisant l'incertitude (**risque**) et en agissant avec intégrité vis-à-vis des lois, normes et contrats (**conformité**). Le terme a été formalisé par l'OCEG autour de l'idée de « *Principled Performance* » : faire les bonnes choses, de la bonne manière.

## 0.1 Les trois piliers et leur boucle de rétroaction

La clé pour **maîtriser** le GRC (et non juste le réciter) est de comprendre que les trois piliers ne sont pas côte à côte : ils forment une **boucle**. La gouvernance émet des décisions ; l'analyse de risque les nourrit d'informations sur ce qui menace réellement l'organisation ; la conformité impose des contraintes d'entrée (des obligations non négociables) et vérifie que le tout tient. Puis on recommence, car le contexte change.

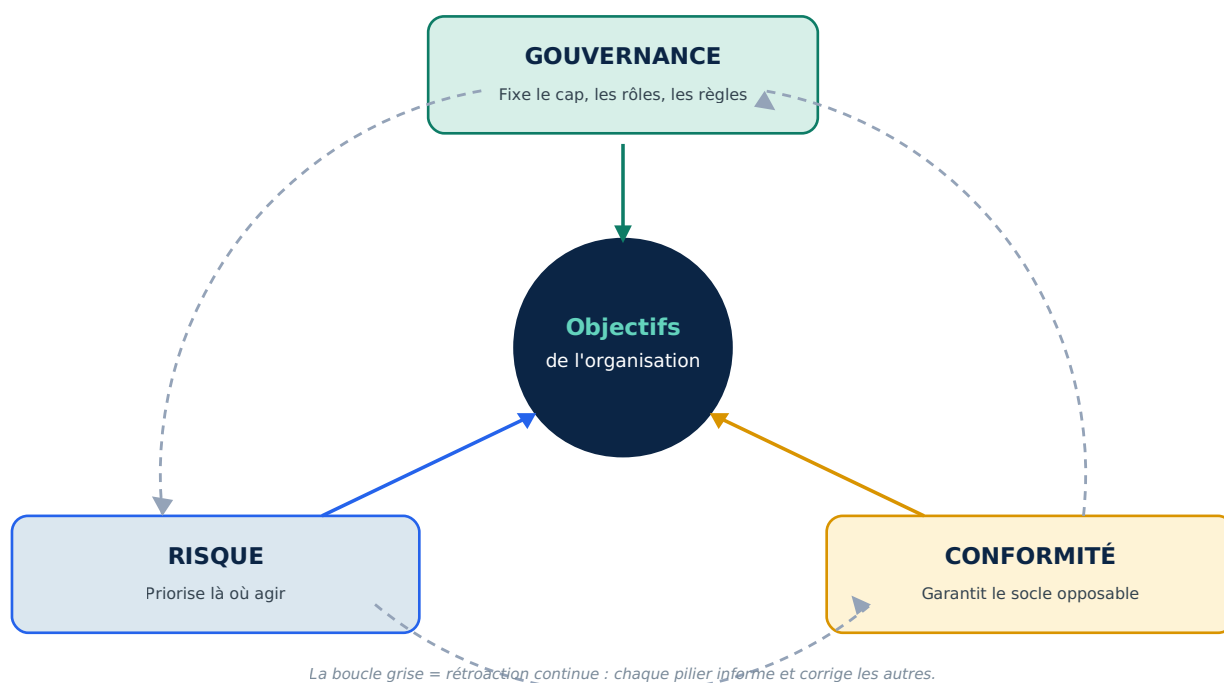


Figure 0.1 — La boucle GRC : trois piliers au service des objectifs, en amélioration continue.

| Pilier             | Question fondatrice                                                         | Ce qu'il produit concrètement                                                         |
|--------------------|-----------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| <b>Gouvernance</b> | « Qui décide quoi, selon quelles règles, et dans quel but ? »               | Stratégie, politiques (PSSI), organisation, rôles, comités, indicateurs de pilotage.  |
| <b>Risque</b>      | « Qu'est-ce qui peut empêcher d'atteindre les objectifs, et que fait-on ? » | Analyse de risque, registre des risques, plan de traitement, risque résiduel accepté. |
| <b>Conformité</b>  | « Respectons-nous nos obligations, et pouvons-nous le prouver ? »           | Déclaration d'applicabilité, preuves, rapports d'audit, plans d'action correctifs.    |

## 0.2 Pourquoi « intégré » change tout

Historiquement, quatre équipes travaillaient séparément : la sécurité, l'audit interne, le juridique/conformité et la gestion des risques. Chacune avait son référentiel, son vocabulaire, ses tableurs. Résultat : des **contrôles redondants**, des **angles morts** entre équipes, des données contradictoires et une « fatigue de l'audit » (les mêmes preuves demandées dix fois). Le GRC **intégré** répond à ce désordre en mutualisant trois choses :

- un **référentiel de contrôles unique** (un contrôle peut satisfaire ISO 27001, le RGPD et un client à la fois) ;
- un **langage de risque commun** (une même échelle, une même définition d'« élevé ») ;
- une **collecte de preuves centralisée** (souvent via un outil GRC : RSA Archer, ServiceNow IRM, OneTrust, Vanta, Drata...).

### APPROFONDISSEMENT — GRC VS IRM VS ERM

Tu croiseras des termes proches. **ERM** (Enterprise Risk Management) est la gestion du risque *global* de l'entreprise (financier, stratégique, opérationnel, pas seulement cyber). **IRM** (Integrated Risk Management, terme de Gartner) insiste sur l'intégration technologique du risque. Le **GRC** ajoute explicitement la **gouvernance** et la **conformité** au risque. Dans ce manuel, on parle surtout du GRC appliqué à la **sécurité de l'information**, mais la mécanique est la même à l'échelle de toute l'entreprise.

## 0.3 Le moteur commun : l'amélioration continue (PDCA)

Le GRC n'est jamais « fini ». Le monde change (nouvelles menaces, nouvelles lois, nouveaux systèmes), donc les décisions doivent être revues. Ce mouvement perpétuel s'appuie sur la **roue de Deming** ou **PDCA**, que tu retrouveras au cœur d'ISO 27001 et de presque toutes les normes de management.

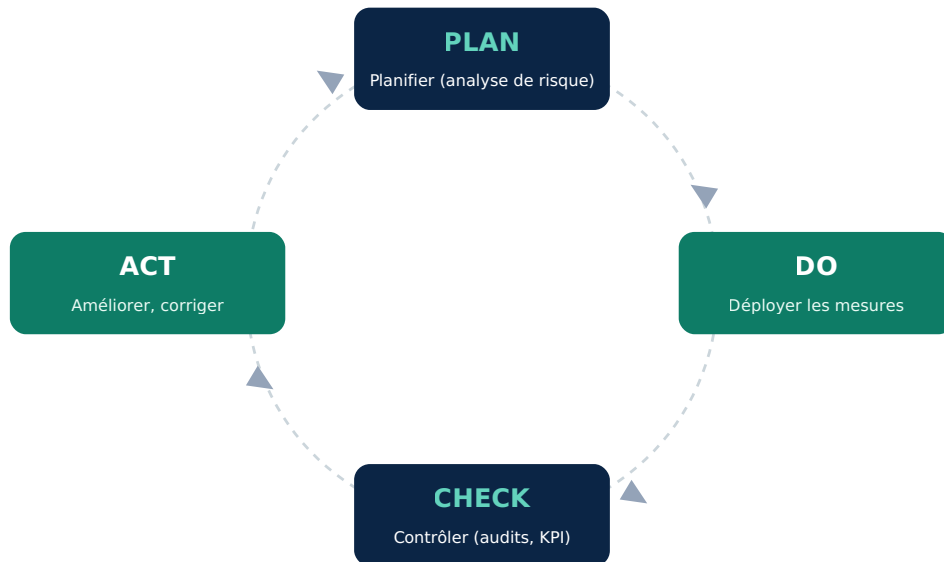


Figure 0.2 — Le cycle PDCA : la sécurité se pilote comme une roue qui tourne, jamais comme un projet à date de fin.

#### À RETENIR — LA PARTIE 0 EN UNE IDÉE

Le GRC transforme la sécurité d'une somme de gestes techniques isolés en un **système piloté**, aligné sur les objectifs, priorisé par le risque, borné par la conformité, et **amélioré en continu**. Tout le reste du manuel détaille les rouages de ce système.

# 1 Gouvernance : diriger et responsabiliser

La gouvernance est le pilier le plus abstrait, donc le plus mal compris. Son rôle est simple à énoncer : **donner une direction et s'assurer qu'elle est suivie**. Elle ne « fait » pas la sécurité au quotidien — elle décide de ce qui compte, nomme des responsables et vérifie que le système fonctionne.

## 1.1 La nature de la gouvernance

### DÉFINITION — GOUVERNANCE DE LA SÉCURITÉ DE L'INFORMATION

Ensemble des **responsabilités, processus et pratiques** par lesquels la direction dirige et contrôle la sécurité, en veillant à ce qu'elle **soutienne les objectifs métier**, que le risque soit géré à un niveau approprié et que les ressources soient employées de façon responsable (esprit de la norme ISO/IEC 27014).

Une gouvernance efficace poursuit six finalités qui reviennent dans toutes les références :

|                                              |                                                                                           |
|----------------------------------------------|-------------------------------------------------------------------------------------------|
| <b>Alignement stratégique</b>                | La sécurité sert les objectifs métier, pas l'inverse.                                     |
| <b>Gestion du risque</b>                     | Le risque est maintenu dans les limites acceptées par la direction.                       |
| <b>Création / préservation de valeur</b>     | La sécurité protège la capacité à créer de la valeur (continuité, confiance, réputation). |
| <b>Optimisation des ressources</b>           | On investit là où le risque le justifie, pas partout au hasard.                           |
| <b>Mesure de la performance</b>              | On sait dire si la sécurité progresse (indicateurs, maturité).                            |
| <b>Reddition de comptes (accountability)</b> | Chacun répond de son périmètre ; les décisions sont tracées.                              |

### Gouvernance vs management : la distinction structurante

C'est la confusion à éliminer. La gouvernance **évalue, oriente et surveille** (modèle **EDM** de COBIT). Le management **planifie, construit, exécute et surveille** (**PBRM**). Autrement dit : la gouvernance décide *quoi* viser et vérifie le résultat ; le management décide *comment* y parvenir et le réalise.

| Gouvernance                                    | Management                                   |
|------------------------------------------------|----------------------------------------------|
| Évalue les options, oriente, surveille (EDM).  | Planifie, réalise, exploite, mesure (PBRM).  |
| Fixe la direction et l'appétence au risque.    | Met en œuvre dans le cadre reçu.             |
| Conseil d'administration, comité de direction. | RSSI et équipes opérationnelles.             |
| « <i>Fait-on les bonnes choses ?</i> »         | « <i>Fait-on les choses correctement ?</i> » |

**POINT DE CONFUSION FRÉQUENT**

On croit souvent que le RSSI « fait la gouvernance ». En réalité le RSSI *opère* la sécurité et *rend compte* à la gouvernance. La responsabilité **ultime** reste au conseil d'administration : il ne peut pas la déléguer, même s'il délègue l'exécution. C'est pour cela que NIS2 rend les dirigeants personnellement responsables.

**Comment se fait, concrètement, l'alignement stratégique**

Aligner ne veut pas dire « faire plaisir au business ». Cela veut dire **relier chaque décision de sécurité à un enjeu de l'organisation** : continuité de service, protection de la réputation, obligation réglementaire, confiance des clients, avantage concurrentiel. C'est ce lien qui justifie un budget devant un comité de direction — pas la peur ni la mode technologique. Un investissement de sécurité qu'on ne sait pas rattacher à un objectif métier est un investissement mal gouverné.

**1.2 Structure organisationnelle & rôles**

La gouvernance répartit des **responsabilités**. Voici les rôles à connaître et surtout à savoir **distinguer**, car les confondre est l'erreur la plus commune.

| Rôle                                        | Mission                                                                                                                                                                             |
|---------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Conseil d'administration / Board</b>     | Responsabilité <i>ultime</i> . Approuve la stratégie, fixe l'appétence au risque, exige des comptes.                                                                                |
| <b>Comité de direction / COMEX</b>          | Arbitre les grandes décisions, alloue les ressources, porte la culture.                                                                                                             |
| <b>RSSI / CISO</b>                          | Définit et pilote la stratégie de sécurité, la PSSI, l'analyse de risque, la sensibilisation, la réponse à incident. C'est l'interface entre la direction et la technique.          |
| <b>DPO / DPD</b>                            | Veille à la conformité RGPD, conseille, tient le registre des traitements, point de contact de la CNIL. <b>Indépendant</b> , rattaché au plus haut niveau, sans conflit d'intérêts. |
| <b>Risk Manager</b>                         | Anime le processus de gestion des risques (au-delà du cyber), consolide le registre des risques.                                                                                    |
| <b>Auditeur (interne / externe)</b>         | Évalue <i>indépendamment</i> l'efficacité des contrôles. Ne peut auditer ce qu'il a lui-même conçu (séparation).                                                                    |
| <b>Propriétaire de l'actif (Data Owner)</b> | Rôle <b>métier</b> : il <i>décide</i> de la classification de l'actif et de qui y a accès.                                                                                          |
| <b>Dépositaire (Data Custodian)</b>         | Rôle <b>technique</b> (IT) : il <i>met en œuvre</i> les protections décidées par le propriétaire.                                                                                   |
| <b>Utilisateur</b>                          | Applique les politiques. Maillon le plus ciblé (hameçonnage, ingénierie sociale).                                                                                                   |

**À RETENIR — PROPRIÉTAIRE VS DÉPOSITAIRE**

Le **propriétaire** (métier) *décide* ; le **dépositaire** (IT) *exécute*. Exemple : la responsable du service médical décide que les dossiers patients sont « confidentiels » et que seuls les soignants y accèdent (propriétaire) ; l'équipe infra chiffre la base et configure les droits (dépositaire). Le propriétaire reste responsable de la donnée ; il ne « refile » pas cette responsabilité à l'IT.

## Les trois lignes de maîtrise

Ce modèle (de l'IIA) explique comment une organisation se contrôle elle-même sans que « celui qui fait » soit aussi « celui qui vérifie ». C'est une application directe de la **séparation des tâches** à l'échelle organisationnelle.



Figure 1.1 — Le modèle des trois lignes : qui gère le risque, qui le surveille, qui en donne une assurance indépendante.

## 1.3 Hiérarchie documentaire & principes fondateurs

La gouvernance s'exprime par des documents, organisés du plus stable (le « pourquoi ») au plus opérationnel (le « comment exact »). Comprendre cette pyramide évite l'erreur classique de mélanger une intention avec une consigne technique.

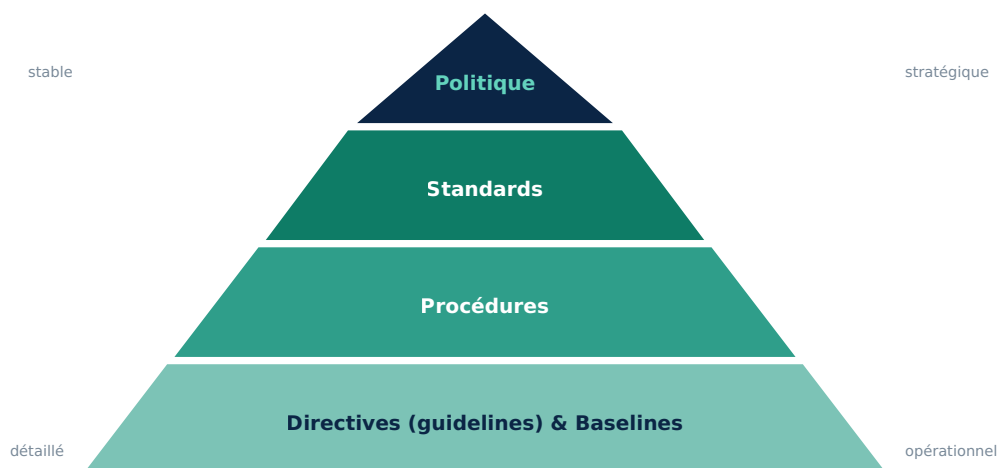


Figure 1.2 — La pyramide documentaire : de l'intention obligatoire (haut) à la consigne concrète (bas).

| Document                     | Portée                                  | Exemple (contexte clinique)                                                           |
|------------------------------|-----------------------------------------|---------------------------------------------------------------------------------------|
| <b>Politique</b>             | Obligatoire, stratégique, stable.       | « Toute donnée de santé doit être protégée en confidentialité et intégrité. »         |
| <b>Standard</b>              | Obligatoire, précis, mesurable.         | « Le chiffrement au repos utilise AES-256 ; les mots de passe font ≥ 12 caractères. » |
| <b>Procédure</b>             | Obligatoire, étape par étape.           | « Procédure de création d'un compte soignant et d'attribution des droits. »           |
| <b>Directive (guideline)</b> | <i>Recommandée</i> , non contraignante. | « Il est conseillé de verrouiller sa session en s'absentant. »                        |
| <b>Baseline</b>              | Configuration minimale de référence.    | « Durcissement selon le CIS Benchmark pour le serveur applicatif. »                   |

En France, le document chapeau qui porte l'ensemble s'appelle la **PSSI** (Politique de Sécurité du Système d'Information).

## Le triptyque DICP / CIA : la grammaire de la sécurité

Tout objectif de sécurité se ramène à ces critères. Les maîtriser, c'est pouvoir **qualifier n'importe quel incident** et choisir la bonne parade.

| Critère                     | Signification                                                             | Atteinte typique & parade                                          |
|-----------------------------|---------------------------------------------------------------------------|--------------------------------------------------------------------|
| <b>Confidentialité</b>      | Seules les personnes autorisées accèdent à l'information.                 | Fuite de données → chiffrement, contrôle d'accès.                  |
| <b>Intégrité</b>            | L'information n'est pas altérée de façon non autorisée.                   | Falsification, injection → signatures, hachage, contrôle d'entrée. |
| <b>Disponibilité</b>        | L'information ou le service est accessible au moment voulu.               | DDoS, ransomware, panne → redondance, sauvegardes, PRA.            |
| <b>Preuve / Traçabilité</b> | On peut prouver qui a fait quoi et quand (non-répudiation, imputabilité). | Logs absents ou altérés → journalisation intègre, horodatage.      |

Modèle étendu : le **Parkerian Hexad** ajoute la possession/le contrôle, l'authenticité et l'utilité. En France on parle de **DIC** ou **DICP/DICT**.

## Les principes fondateurs (et pourquoi ils existent)

| Principe                               | Idée & raison d'être                                                                                     |
|----------------------------------------|----------------------------------------------------------------------------------------------------------|
| <b>Moindre privilège</b>               | Ne donner que les droits strictement nécessaires. Limite les dégâts si un compte est compromis.          |
| <b>Besoin d'en connaître</b>           | Accès à l'information seulement si la mission l'exige. Réduit la surface d'exposition.                   |
| <b>Séparation des tâches (SoD)</b>     | Aucune personne ne maîtrise seule un processus critique de bout en bout. Prévient la fraude et l'erreur. |
| <b>Défense en profondeur</b>           | Empiler plusieurs couches : si l'une cède, les autres tiennent (voir §3.3).                              |
| <b>Sécurité by design / by default</b> | Intégrer la sécurité dès la conception et l'activer par défaut. Exigence du RGPD (art. 25).              |
| <b>Fail secure</b>                     | En cas de panne, rester dans un état sûr plutôt qu'ouvert.                                               |
| <b>Économie de mécanisme (KISS)</b>    | Plus un système est simple, plus il est vérifiable et sûr.                                               |

## 1.4 Culture, maturité et pilotage par la mesure

On ne gouverne bien que ce que l'on mesure. La gouvernance s'appuie sur des indicateurs, un modèle de maturité et une répartition claire des responsabilités.

### KPI vs KRI

| KPI — indicateur de performance                          | KRI — indicateur de risque                                          |
|----------------------------------------------------------|---------------------------------------------------------------------|
| Mesure si un objectif est atteint (regard rétrospectif). | Signal <b>avant-coureur</b> d'une exposition croissante.            |
| Ex : % de serveurs corrigés sous 30 jours.               | Ex : nombre de vulnérabilités critiques ouvertes depuis > 60 jours. |
| « Où en sommes-nous ? »                                  | « Vers quoi allons-nous ? »                                         |

### La matrice RACI

Pour chaque activité, on précise : **R**esponsible (exécute), **A**ccountable (rend des comptes — **un seul**), **C**onsulted (consulté avant), **I**nformed (informé après). C'est l'outil anti-« ce n'était pas moi ». Règle d'or : plusieurs R possibles, mais **un seul A** par activité, sinon la responsabilité se dilue.

### L'échelle de maturité

Pour montrer une **trajectoire de progrès** (et non un état figé), on situe chaque processus sur une échelle inspirée de CMMI.

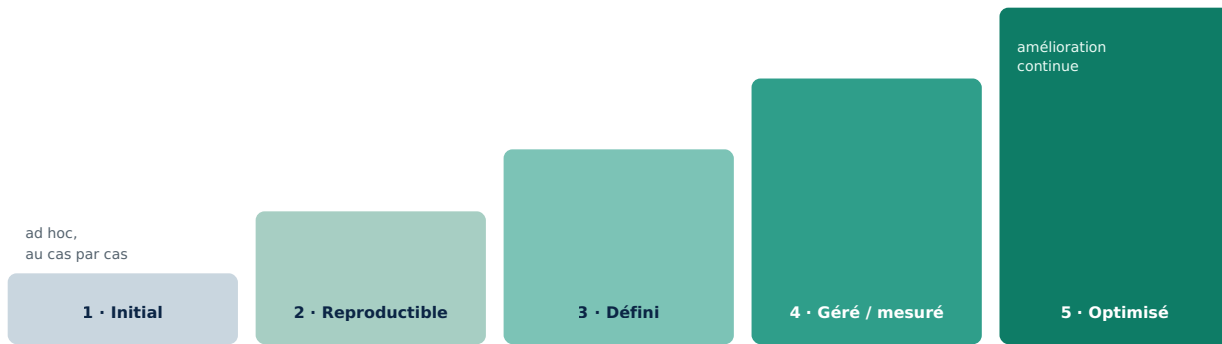


Figure 1.3 — L'échelle de maturité (0 « inexistant » précède le niveau 1) : de l'improvisation à l'amélioration continue.

## 2

# Risque : maîtriser l'incertitude

Si la gouvernance fixe le cap, la gestion du risque répond à la question qui décide de **où mettre l'effort**. On ne peut pas tout protéger également : le risque est l'outil qui hiérarchise. C'est le pilier le plus « scientifique » du GRC.

## 2.1 L'anatomie d'un risque

### DÉFINITION — RISQUE

Le **risque** est l'effet de l'incertitude sur l'atteinte des objectifs (ISO 31000). En sécurité, c'est la **combinaison de la vraisemblance** qu'une menace exploite une vulnérabilité **et de l'impact** qui en résulterait sur un actif de valeur.

Un risque n'est pas un objet unique : c'est une **chaîne**. Comprendre chaque maillon permet d'agir au bon endroit (supprimer la vulnérabilité, réduire l'exposition, limiter l'impact...).

| Terme                            | Définition                                                    | Exemple                                            |
|----------------------------------|---------------------------------------------------------------|----------------------------------------------------|
| <b>Actif (asset)</b>             | Ce qui a de la valeur et qu'on protège.                       | La base des dossiers patients.                     |
| <b>Source de risque / menace</b> | L'acteur ou l'origine (humaine, technique, environnementale). | Un groupe de rançongiciel.                         |
| <b>Vulnérabilité</b>             | La faiblesse exploitable.                                     | Un serveur non corrigé, exposé sur Internet.       |
| <b>Exploitation</b>              | Le moyen concret d'utiliser la faille.                        | Un exploit d'une CVE connue.                       |
| <b>Événement redouté</b>         | Ce que l'on craint (vocabulaire EBIOS).                       | La fuite des données de santé.                     |
| <b>Impact / conséquence</b>      | Le dommage si l'événement survient.                           | Amende, perte de confiance, interruption de soins. |
| <b>Vraisemblance</b>             | La probabilité d'occurrence.                                  | Élevée pour un service exposé et non corrigé.      |

### À RETENIR — LES ÉQUATIONS DU RISQUE

Forme conceptuelle : **Risque = Menace × Vulnérabilité × Impact**.

Forme opérationnelle : **Risque = Vraisemblance × Impact**.

La conséquence pratique est importante : un risque n'existe que si les maillons coexistent. Une menace sans vulnérabilité exploitable, ou une vulnérabilité sans menace, ou une faille sur un actif sans valeur → **pas de risque significatif**. C'est ce qui permet de *ne pas* tout traiter.

## 2.2 Le processus de gestion des risques (ISO 31000 / 27005)

La gestion du risque est un **cycle itératif**, pas une étude unique. Le référentiel générique est **ISO 31000** ; sa déclinaison sécurité de l'information est **ISO/IEC 27005**.

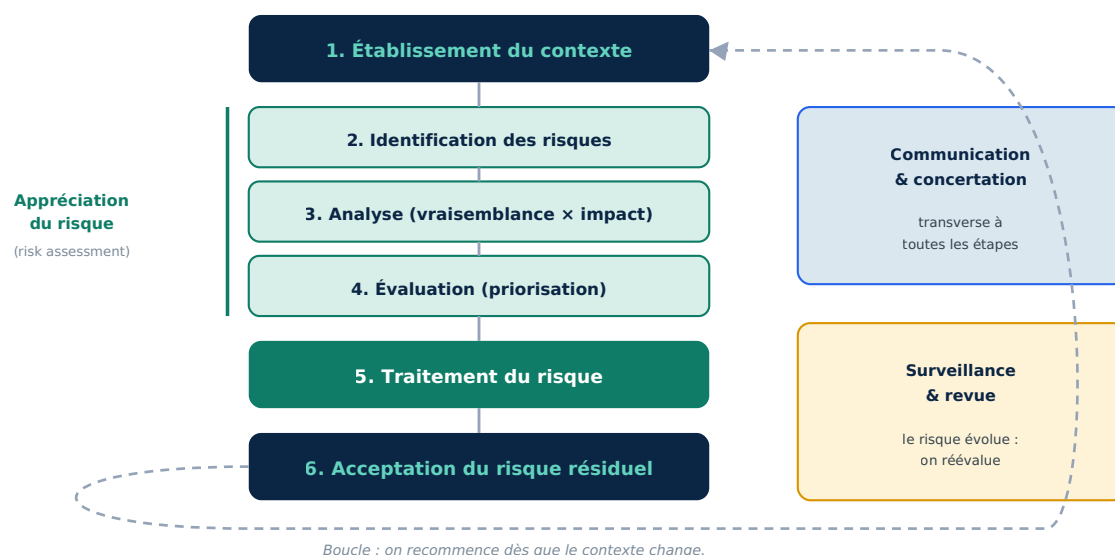


Figure 2.1 — Le cycle de gestion des risques : l'appréciation (2→4) alimente le traitement, le tout sous communication et surveillance continues.

#### APPROFONDISSEMENT — TROIS MOTS À NE PAS CONFONDRE

L'**analyse** du risque = estimer sa vraisemblance et son impact (étape 3). L'**évaluation** = comparer aux critères et prioriser (étape 4). L'**appréciation** (*risk assessment*) = l'ensemble identification + analyse + évaluation (étapes 2 à 4). On réserve donc « appréciation » au tout, « analyse » à l'estimation. Beaucoup les emploient à tort comme synonymes.

## 2.3 Mesurer le risque : qualitatif & quantitatif

| Approche qualitative                                             | Approche quantitative                                               |
|------------------------------------------------------------------|---------------------------------------------------------------------|
| Échelles verbales (faible / moyen / élevé), matrices de couleur. | Valeurs monétaires et probabilités chiffrées.                       |
| Rapide, intuitive, mais subjective.                              | Objective et comparable, mais exige des données.                    |
| Idéale pour <b>trier vite</b> un grand nombre de risques.        | Idéale pour <b>justifier un budget</b> (retour sur investissement). |

En pratique on combine : le **qualitatif** pour dégrossir et prioriser, puis le **quantitatif** sur les quelques risques majeurs qui méritent une décision d'investissement.

## Les formules quantitatives, expliquées

| Sigle       | Nom & sens                                                   | Formule                                       |
|-------------|--------------------------------------------------------------|-----------------------------------------------|
| <b>AV</b>   | Asset Value : valeur de l'actif.                             | en €                                          |
| <b>EF</b>   | Exposure Factor : part de l'actif perdue en un sinistre.     | de 0 à 1                                      |
| <b>SLE</b>  | Single Loss Expectancy : perte pour <i>un</i> sinistre.      | $SLE = AV \times EF$                          |
| <b>ARO</b>  | Annualized Rate of Occurrence : fréquence annuelle attendue. | ex. 0,25 = 1 fois / 4 ans                     |
| <b>ALE</b>  | Annualized Loss Expectancy : perte annualisée.               | $ALE = SLE \times ARO$                        |
| <b>ROSI</b> | Return On Security Investment : rentabilité d'un contrôle.   | $(ALE_0 - ALE_1 - \text{coût}) / \text{coût}$ |

### EXEMPLE CHIFFRÉ, DE BOUT EN BOUT

La base patients vaut **200 000 €** (AV). Un ransomware en détruirait 60 % → **EF = 0,6**, donc **SLE = 120 000 €**. On estime une attaque réussie tous les 4 ans → **ARO = 0,25**, donc **ALE<sub>0</sub> = 30 000 €/an**. On envisage une solution « sauvegardes immuables + EDR » à **8 000 €/an** qui ramène l'ALE à **5 000 €/an** (ALE<sub>1</sub>).

**ROSI = (30 000 – 5 000 – 8 000) / 8 000 = 2,1 → +212 %**. Chaque euro investi en « rapporte » 2,1 en pertes évitées : l'investissement est justifié, et on peut le *démontrer* à la direction. C'est exactement ce que la gouvernance attend du risque : transformer une inquiétude en décision argumentée.

## La matrice de risque (approche qualitative)

| Vraisemblance ↓ / Impact → | Négligeable | Mineur      | Modéré | Majeur   | Critique |
|----------------------------|-------------|-------------|--------|----------|----------|
| <b>Très probable</b>       | Moyen       | Élevé       | Élevé  | Critique | Critique |
| <b>Probable</b>            | Faible      | Moyen       | Élevé  | Élevé    | Critique |
| <b>Possible</b>            | Faible      | Moyen       | Moyen  | Élevé    | Élevé    |
| <b>Peu probable</b>        | Très faible | Faible      | Moyen  | Moyen    | Élevé    |
| <b>Rare</b>                | Très faible | Très faible | Faible | Moyen    | Moyen    |

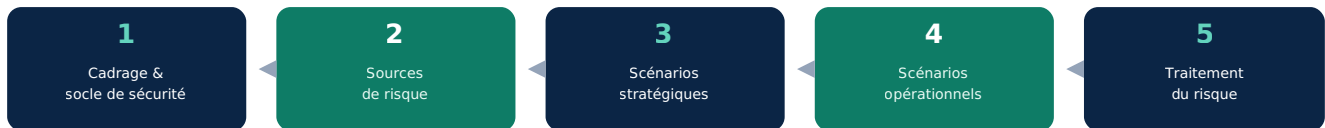
La couleur d'une case place le risque au-dessus ou en-dessous du **seuil d'acceptation** fixé par la gouvernance : c'est le pont entre le risque (§2) et la décision (§1).

## 2.4 Les méthodes d'analyse de risque

### EBIOS Risk Manager (ANSSI) — référence en France

Méthode française de l'ANSSI, orientée **scénarios de menace** et **écosystème** (elle prend en compte les attaques passant par les partenaires et fournisseurs). Elle s'organise en **5 ateliers**. Voici leur logique, illustrée sur un fil rouge « portail patient d'une clinique ».

## EBIOS Risk Manager — 5 ateliers



Du « que doit-on protéger et contre quel socle » au « quelles mesures et quel risque résiduel ».

Figure 2.2 — Les cinq ateliers d'EBIOS RM, du cadrage au plan de traitement.

| # | Atelier                                | Ce qu'on y fait & exemple (portail patient)                                                                                                                                                                                   |
|---|----------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1 | <b>Cadrage &amp; socle de sécurité</b> | Définir le périmètre, les valeurs métier, les événements redoutés, et l'écart au socle réglementaire. <i>Ex : valeur = confidentialité des dossiers ; événement redouté = fuite massive ; socle = RGPD + hébergement HDS.</i> |
| 2 | <b>Sources de risque</b>               | Identifier les couples « source de risque / objectif visé » pertinents. <i>Ex : cybercriminel cherchant à revendre des données de santé ; hacktiviste ; salarié malveillant.</i>                                              |
| 3 | <b>Scénarios stratégiques</b>          | Tracer les chemins d'attaque de haut niveau <b>via l'écosystème</b> . <i>Ex : l'attaquant passe par le prestataire d'hébergement ou l'éditeur d'un module tiers.</i>                                                          |
| 4 | <b>Scénarios opérationnels</b>         | Détailler les modes opératoires techniques (proche de la kill chain / MITRE ATT&CK). <i>Ex : hameçonnage d'un admin → élévation de privilèges → exfiltration → chiffrement.</i>                                               |
| 5 | <b>Traitement du risque</b>            | Choisir les mesures, bâtir le plan d'amélioration continue, statuer sur le <b>risque résiduel</b> . <i>Ex : MFA obligatoire, segmentation, sauvegardes immuables, surveillance du prestataire.</i>                            |

## Panorama des autres méthodes

| Méthode                     | Origine     | Caractéristique & usage                                                                                                                         |
|-----------------------------|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>ISO/IEC 27005</b>        | ISO         | Cadre générique de gestion du risque SI, s'articule avec ISO 27001. Non prescriptif sur la technique employée.                                  |
| <b>NIST RMF</b> (SP 800-37) | NIST (US)   | 6 étapes : Categorize, Select, Implement, Assess, Authorize, Monitor. Lié au catalogue de contrôles 800-53.                                     |
| <b>NIST SP 800-30</b>       | NIST (US)   | Guide de conduite d'une analyse de risque (le « comment estimer »).                                                                             |
| <b>FAIR</b>                 | Open Group  | Purement <b>quantitatif</b> : décompose le risque en fréquence × magnitude et produit des distributions monétaires (simulation de Monte-Carlo). |
| <b>MEHARI</b>               | CLUSIF (FR) | Méthode française historique, riche base de scénarios.                                                                                          |
| <b>OCTAVE</b>               | CERT / CMU  | Auto-évaluation pilotée par l'organisation, centrée sur les actifs.                                                                             |

### APPROFONDISSEMENT — COMMENT CHOISIR ?

On ne « choisit » pas une méthode dans l'absolu, mais selon le contexte : **EBIOS RM** si l'on est en France / secteur public / on veut le regard « scénarios & écosystème » ; **ISO 27005** si l'on vise une certification ISO 27001 ; **FAIR** si la direction veut des euros et un raisonnement financier ; **NIST** dans un contexte américain ou pour un catalogue de contrôles détaillé. Toutes partagent la même logique de fond (identifier → analyser → traiter).

## 2.5 Traiter le risque, résiduel, appétence, registre

### Les quatre stratégies de traitement (« les 4 T »)

| Stratégie                    | Terme ISO 27005     | Idée & exemple                                                                                                    |
|------------------------------|---------------------|-------------------------------------------------------------------------------------------------------------------|
| <b>Réduire / Traiter</b>     | Modifier le risque  | Ajouter des contrôles pour baisser vraisemblance ou impact. Ex : MFA, correctifs, chiffrement.                    |
| <b>Éviter / Refuser</b>      | Éviter le risque    | Supprimer la source du risque. Ex : renoncer à une fonctionnalité, décommissionner un serveur.                    |
| <b>Transférer / Partager</b> | Partager le risque  | Reporter l'impact via assurance, sous-traitance, clause contractuelle.                                            |
| <b>Accepter / Tolérer</b>    | Conserver le risque | Assumer sciemment quand le coût du contrôle dépasse l'impact. <b>Validation formelle</b> de la direction requise. |

#### POINT DE CONFUSION FRÉQUENT

« Transférer » un risque ne supprime **pas la responsabilité**. Une assurance couvre la perte financière, un sous-traitant exécute une tâche — mais l'atteinte à la réputation reste tienne, et juridiquement le RGPD rappelle que **le responsable de traitement demeure responsable** même lorsqu'il sous-traite. On transfère l'impact, jamais l'imputabilité.

### Risque inhérent, résiduel, et le rôle de l'acceptation

Le **risque inhérent** est le niveau *avant* tout contrôle. Le **risque résiduel** est ce qui subsiste *après* les contrôles. On ne vise jamais le risque zéro (impossible et ruineux) : on ramène le résiduel **sous le seuil d'acceptation** défini par la gouvernance, puis la direction **l'accepte formellement**. Cette acceptation explicite est essentielle : c'est elle qui rend la décision *traçable* et engage la responsabilité au bon niveau.

$$\text{Risque résiduel} = \text{Risque inhérent} - \text{Effet des contrôles} \leq \text{Seuil d'acceptation}$$

### Appétence, tolérance, capacité

|                            |                                                                                                                                  |
|----------------------------|----------------------------------------------------------------------------------------------------------------------------------|
| <b>Appétence au risque</b> | Niveau de risque que l'organisation est <i>prête</i> à accepter pour atteindre ses objectifs. Choix stratégique de la direction. |
| <b>Tolérance au risque</b> | Marge de variation acceptable autour de l'appétence.                                                                             |
| <b>Capacité au risque</b>  | Niveau <i>maximal</i> supportable sans mettre en péril la survie de l'organisation.                                              |

### Le registre des risques — le livrable central

Document vivant qui trace chaque risque de bout en bout. Exemple d'entrée :

| ID   | Risque                                                    | V     | I         | Ni-veau | Traitement                                                         | Rési-duel | Pro-prié-taire |
|------|-----------------------------------------------------------|-------|-----------|---------|--------------------------------------------------------------------|-----------|----------------|
| R-07 | Fuite de dossiers patients via serveur non corrigé exposé | Prob. | Ma-jeur   | Élevé   | Réduire : patch mensuel, WAF, MFA, segmentation                    | Moyen     | RSSI           |
| R-12 | Indisponibilité par ransomware                            | Poss. | Cri-tique | Élevé   | Réduire + transférer : sauvegardes immuables, EDR, cyber-assurance | Moyen     | DSI            |

Un bon registre relie explicitement chaque risque à son **propriétaire**, à un **plan d'action daté** et à un **statut** — sinon il ne « vit » pas.

## 2.6 Risque tiers & chaîne d'approvisionnement

De plus en plus d'attaques passent par les **fournisseurs** plutôt que par la cible directe : c'est le risque de la **supply chain**. Le **TPRM** (Third-Party Risk Management) l'encadre par : questionnaires de sécurité, exigences contractuelles (SLA, notification d'incident, droit d'audit), certifications requises (ISO 27001, SOC 2), clauses RGPD (art. 28 pour les sous-traitants), et surveillance continue.

### APPROFONDISSEMENT — DEUX CAS EMBLÉMATIQUES

**SolarWinds (2020)** : des attaquants ont compromis la *chaîne de mise à jour* d'un logiciel de supervision, atteignant des milliers d'organisations d'un coup. **Log4Shell / Log4j (2021)** : une faille critique dans une simple bibliothèque de journalisation, utilisée partout, a exposé d'innombrables applications. Leçon commune : ton risque dépend aussi du code et des services que tu *n'as pas écrits*. C'est pourquoi **NIS2** impose désormais de gérer explicitement le risque de la chaîne d'approvisionnement.

## 3

## Conformité : le socle opposable

La conformité est le pilier le plus concret : elle répond à des obligations extérieures (lois, normes, contrats). Son piège est de croire qu'elle *suffit*. Elle est un **plancher** — le minimum vérifiable — et non une garantie de sécurité.

### 3.1 Nature et distinctions

#### DÉFINITION — CONFORMITÉ

La **conformité** est le fait de **respecter les obligations** auxquelles l'organisation est soumise (lois, règlements, normes, contrats, politiques internes) **et de pouvoir le prouver**. Elle produit un socle minimal opposable devant un régulateur, un juge ou un client.

#### POINT DE CONFUSION FONDAMENTAL — CONFORMITÉ ≠ SÉCURITÉ

On peut être 100 % conforme à une norme et se faire pirater : soit parce que les contrôles sont cochés mais mal appliqués, soit parce que la menace réelle n'est pas couverte par la norme. Inversement, une organisation peut être très sécurisée sans certificat. **La conformité est un plancher, pas un plafond.** La vraie sécurité vient de l'analyse de risque (§2), la conformité en garantit le minimum incompressible.

#### Loi, norme, framework, contrat

| Type                        | Nature                                                                    | Exemples                                                        |
|-----------------------------|---------------------------------------------------------------------------|-----------------------------------------------------------------|
| <b>Loi / Règlement</b>      | Obligatoire, sanctions légales.                                           | RGPD, NIS2, DORA, LPM, HIPAA, SOX.                              |
| <b>Norme / Standard</b>     | Référentiel certifiable, souvent volontaire (parfois imposé par contrat). | ISO 27001, PCI-DSS.                                             |
| <b>Framework</b>            | Cadre méthodologique, non certifiable en soi.                             | NIST CSF, COBIT, CIS Controls.                                  |
| <b>Contrat / Engagement</b> | Obligation entre deux parties.                                            | Clause de sécurité client, SLA, accord de sous-traitance (DPA). |

#### Conformité, attestation, certification

|                      |                                                                                                                                  |
|----------------------|----------------------------------------------------------------------------------------------------------------------------------|
| <b>Conformité</b>    | État de respect d'une exigence (auto-déclaré ou vérifié).                                                                        |
| <b>Attestation</b>   | Un tiers atteste d'un état à un instant ou sur une période (ex. rapport SOC 2 par un cabinet).                                   |
| <b>Certification</b> | Un organisme accrédité délivre un certificat selon un schéma (ex. ISO 27001, valable 3 ans avec audits de surveillance annuels). |

### 3.2 L'audit, moteur de la conformité

Sans vérification, la conformité n'est qu'une déclaration. L'**audit** confronte les affirmations aux **preuves**. Il suit un cycle stable.



Figure 3.1 — Le déroulé type d'un audit : de la définition du périmètre à la clôture des actions correctives.

| Notion                                | Sens                                                                                                                                              |
|---------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Preuve (evidence)</b>              | Élément attestant qu'un contrôle existe et fonctionne (capture, log, entretien, test, échantillon).                                               |
| <b>Écart / non-conformité</b>         | Différence entre l'exigence et la réalité. Classée <b>majeure</b> (peut bloquer une certification), <b>mineure</b> ou simple <b>observation</b> . |
| <b>Plan d'action correctif (CAPA)</b> | Ensemble des mesures pour combler les écarts, avec responsable et échéance.                                                                       |
| <b>Revue de direction</b>             | Réexamen périodique du système par la direction (exigé par ISO 27001).                                                                            |

| Type d'audit                | Qui / pourquoi                                                |
|-----------------------------|---------------------------------------------------------------|
| <b>1re partie (interne)</b> | L'organisation s'auto-évalue ; prépare aux audits externes.   |
| <b>2e partie</b>            | Un client ou partenaire audite son fournisseur.               |
| <b>3e partie (externe)</b>  | Organisme indépendant accrédité (certification, attestation). |

### 3.3 Les contrôles de sécurité

Un **contrôle** (mesure de sécurité) est ce qui réduit concrètement un risque. On les classe par **fonction** (à quel moment ils agissent) et par **nature** (comment ils sont mis en œuvre).

#### PAR FONCTION

| Fonction             | But                                                 | Exemple                                           |
|----------------------|-----------------------------------------------------|---------------------------------------------------|
| <b>Préventif</b>     | Empêcher l'incident.                                | Pare-feu, MFA, chiffrement, formation.            |
| <b>Détectif</b>      | Repérer l'incident.                                 | SIEM, IDS, journalisation, antivirus.             |
| <b>Correctif</b>     | Réparer après coup.                                 | Restauration de sauvegarde, correctif, isolement. |
| <b>Dissuasif</b>     | Décourager l'attaquant.                             | Bannière légale, mention de vidéosurveillance.    |
| <b>Directif</b>      | Imposer un comportement.                            | Politique, procédure, consigne.                   |
| <b>Compensatoire</b> | Alternative quand le contrôle idéal est impossible. | Surveillance renforcée à défaut de segmentation.  |
| <b>Récupération</b>  | Rétablir les opérations.                            | PRA, site de secours.                             |

## PAR NATURE

|                                        |                                                          |
|----------------------------------------|----------------------------------------------------------|
| <b>Technique / logique</b>             | Mis en œuvre par la technologie (chiffrement, ACL, IDS). |
| <b>Administratif / organisationnel</b> | Politiques, procédures, formation, gestion RH.           |
| <b>Physique</b>                        | Serrures, badges, zonage, détection incendie.            |

### POINT DE CONFUSION FRÉQUENT

Un même contrôle peut **cumuler plusieurs fonctions**. Un antivirus *détecte* (signature) et *prévient* (blocage). Une sauvegarde n'est ni préventive ni détective : elle est **corrective / de récupération** (elle n'empêche pas l'incident, elle aide à s'en remettre). Sache toujours *justifier* la classification plutôt que la réciter.

## Le principe qui relie les contrôles : la défense en profondeur

Aucun contrôle n'est parfait. La **défense en profondeur** empile des couches indépendantes : pour atteindre la donnée, un attaquant doit toutes les franchir. Si l'une cède, les autres tiennent. C'est l'application concrète du principe fondateur vu au §1.3.

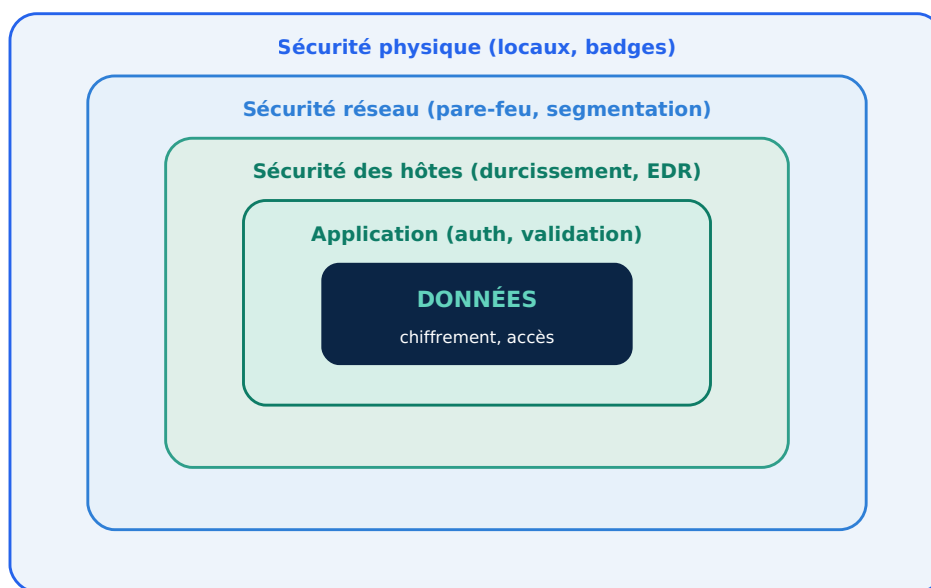


Figure 3.2 — La défense en profondeur : des couches concentriques autour de l'actif le plus précieux, la donnée.

## 4 Normes, frameworks & réglementations

Cette partie est un catalogue raisonné. Ne cherche pas à tout mémoriser d'un coup : comprends d'abord **à quoi sert chaque texte** et **comment ils se répartissent** (norme certifiable vs framework vs loi), puis les détails s'accrocheront naturellement.

### 4.1 ISO/IEC 27001 & la famille 2700x

#### DÉFINITION — ISO/IEC 27001

Norme **internationale certifiable** définissant les exigences d'un **SMSI** (Système de Management de la Sécurité de l'Information) : une manière **systemique et pilotée par le risque** d'établir, mettre en œuvre, maintenir et améliorer la sécurité. Version en vigueur : **ISO/IEC 27001:2022**.

#### Qu'est-ce qu'un « système de management » (et pourquoi c'est central)

Un SMSI n'est pas un ensemble d'outils, c'est une **manière de s'organiser**. La certification ne dit pas « ils sont sécurisés » ; elle dit « ils ont un système *qui pilote* la sécurité, l'améliore et le prouve ». D'où l'importance des clauses 4 à 10, qui décrivent ce système, avant même les mesures techniques de l'Annexe A.

#### Les clauses 4 à 10 (le cœur certifiable), suivant PDCA

| Clause                                | Contenu                                                                 | PDCA  |
|---------------------------------------|-------------------------------------------------------------------------|-------|
| <b>4. Contexte</b>                    | Enjeux internes/externes, parties intéressées, périmètre du SMSI.       | Plan  |
| <b>5. Leadership</b>                  | Engagement de la direction, politique, rôles et responsabilités.        | Plan  |
| <b>6. Planification</b>               | Appréciation & traitement du risque, objectifs, <b>SoA</b> .            | Plan  |
| <b>7. Support</b>                     | Ressources, compétences, sensibilisation, communication, documentation. | Plan  |
| <b>8. Fonctionnement</b>              | Mise en œuvre opérationnelle des traitements du risque.                 | Do    |
| <b>9. Évaluation des performances</b> | Surveillance, mesure, <b>audit interne</b> , revue de direction.        | Check |
| <b>10. Amélioration</b>               | Non-conformités, actions correctives, amélioration continue.            | Act   |

#### L'Annexe A & la Déclaration d'Applicabilité (SoA)

L'**Annexe A** fournit un catalogue de mesures de référence. Depuis 2022 : **93 contrôles** en **4 thèmes** (contre 114 contrôles / 14 domaines en 2013).

| Thème (2022)            | Nb | Exemples                                                         |
|-------------------------|----|------------------------------------------------------------------|
| <b>Organisationnels</b> | 37 | Politiques, gestion des tiers, threat intelligence.              |
| <b>Humains (People)</b> | 8  | Sensibilisation, filtrage RH, télétravail.                       |
| <b>Physiques</b>        | 14 | Zones sécurisées, protection du matériel.                        |
| <b>Technologiques</b>   | 34 | Chiffrement, journalisation, sauvegarde, développement sécurisé. |

### À RETENIR — LE SOA, DOCUMENT PIVOT

La **Déclaration d'Applicabilité** (Statement of Applicability) indique, pour chaque contrôle de l'Annexe A : est-il **applicable** ? est-il **en place** ? et **pourquoi** l'inclure ou l'exclure ? C'est le pont entre l'*analyse de risque* (§2) et les *contrôles réellement retenus* : c'est le premier document qu'un auditeur regarde. Retiens aussi : **27001 = les exigences (certifiable)** ; **27002 = le guide de mise en œuvre des contrôles (non certifiable)**.

## La famille ISO 2700x

|                      |                                                                        |
|----------------------|------------------------------------------------------------------------|
| <b>27001</b>         | Exigences du SMSI (certifiable).                                       |
| <b>27002</b>         | Guide de mise en œuvre des contrôles.                                  |
| <b>27005</b>         | Gestion des risques de sécurité de l'information.                      |
| <b>27017 / 27018</b> | Sécurité du cloud / protection des données personnelles dans le cloud. |
| <b>27701</b>         | Extension « vie privée » (PIMS) — s'articule avec le RGPD.             |
| <b>27035 / 27031</b> | Gestion des incidents / continuité TIC.                                |
| <b>22301</b>         | Management de la continuité d'activité (certifiable).                  |

## 4.2 NIST CSF, 800-53, COBIT, CIS, COSO

### NIST Cybersecurity Framework (CSF 2.0)

Framework volontaire très répandu, structuré en **fonctions**. La version **2.0 (2024)** ajoute **Govern** aux cinq fonctions historiques, désormais au centre.

| Fonction                          | Rôle                                                                     |
|-----------------------------------|--------------------------------------------------------------------------|
| <b>Govern (GV)</b><br>nouveau 2.0 | Stratégie, rôles, gestion du risque, supply chain. Chapeaute les autres. |
| <b>Identify (ID)</b>              | Connaître ses actifs, son environnement et ses risques.                  |
| <b>Protect (PR)</b>               | Mettre en place les protections (accès, formation, données).             |
| <b>Detect (DE)</b>                | Détecter les événements de sécurité.                                     |
| <b>Respond (RS)</b>               | Réagir : réponse à incident, communication.                              |
| <b>Recover (RC)</b>               | Restaurer les capacités et services.                                     |

Mémo des six fonctions : **G-I-P-D-R-R**. Le CSF ajoute aussi des **Tiers** (niveaux de maturité) et des **Profils** (état actuel vs cible).

## Les autres référentiels

| Référentiel                 | Portée & usage                                                                                                                                          |
|-----------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>NIST SP 800-53</b>       | Catalogue très détaillé de contrôles (agences fédérales US), organisé en familles (AC, AU, IR...). Sert de « bibliothèque » de mesures.                 |
| <b>COBIT (2019, ISA-CA)</b> | <b>Gouvernance et gestion de l'IT d'entreprise</b> . Sépare la gouvernance (EDM) du management (APO/BAI/DSS/MEA). Idéal pour l'alignement IT ↔ métier.  |
| <b>CIS Controls v8</b>      | <b>18 contrôles</b> priorités et concrets, en 3 groupes de mise en œuvre (IG1-3). Très opérationnel ; inclut les <b>CIS Benchmarks</b> de durcissement. |
| <b>COSO</b>                 | Contrôle interne (5 composantes) & <b>ERM</b> . Base de la loi SOX. Vision entreprise globale, orientée finance et gouvernance.                         |
| <b>ITIL 4</b>               | Gestion des services IT (incidents, changements) — connexe à la sécurité.                                                                               |
| <b>MITRE ATT&amp;CK</b>     | Base de connaissances des tactiques et techniques adverses. Alimente la détection et les scénarios (EBIOS atelier 4).                                   |

### À RETENIR — COMMENT ILS SE COMPLÈTENT

**ISO 27001** = norme certifiable, le *système* de management (le « quoi »). **NIST CSF** = framework flexible d'auto-évaluation par fonctions (le « comment s'organiser »). **COBIT** = gouvernance IT globale et alignement (le « qui décide et aligne »). **CIS / 800-53** = catalogues de *contrôles* concrets (le « avec quelles mesures »). Ils ne s'opposent pas : on peut piloter un SMSI ISO 27001 en s'appuyant sur les mesures CIS et en communiquant via les fonctions du CSF.

## 4.3 Réglementations UE & France

### RGPD / GDPR — à maîtriser en priorité

#### DÉFINITION — RGPD

Règlement européen (UE 2016/679, applicable depuis le **25 mai 2018**) encadrant le traitement des **données à caractère personnel**. Portée **extraterritoriale** : il s'applique dès qu'on cible des personnes situées dans l'UE, où que soit l'organisation.

## LES 6 PRINCIPES (+ ACCOUNTABILITY) — ART. 5

|                                          |                                                             |
|------------------------------------------|-------------------------------------------------------------|
| <b>Licéité, loyauté, transparence</b>    | Traitement légal, honnête, compréhensible pour la personne. |
| <b>Limitation des finalités</b>          | But déterminé, explicite et légitime ; pas de détournement. |
| <b>Minimisation</b>                      | Uniquement les données nécessaires.                         |
| <b>Exactitude</b>                        | Données à jour et correctes.                                |
| <b>Limitation de conservation</b>        | Durée de conservation bornée.                               |
| <b>Intégrité &amp; confidentialité</b>   | Sécurité appropriée — <b>le lien direct avec la cyber.</b>  |
| <b>+ Responsabilité (accountability)</b> | Être capable de <b>prouver</b> sa conformité à tout moment. |

## LES 6 BASES LÉGALES — ART. 6

Tout traitement doit reposer sur **au moins une** base : consentement · exécution d'un contrat · obligation légale · intérêts vitaux · mission d'intérêt public · **intérêt légitime**.

## LES DROITS DES PERSONNES

Accès · rectification · effacement (« droit à l'oubli ») · limitation · **portabilité** · opposition · ne pas subir une décision entièrement **automatisée**.

## LES NOTIONS STRUCTURANTES

|                                                 |                                                                                                           |
|-------------------------------------------------|-----------------------------------------------------------------------------------------------------------|
| <b>Responsable de traitement</b>                | Détermine les finalités et les moyens.                                                                    |
| <b>Sous-traitant</b> (art. 28)                  | Traite pour le compte du responsable ; contrat / DPA obligatoire.                                         |
| <b>Donnée sensible</b> (art. 9)                 | Santé, biométrie, opinions, orientation... → protection renforcée. ( <i>Cœur de sujet pour ClinIQ.</i> )  |
| <b>AIPD / DPIA / PIA</b>                        | Analyse d'impact obligatoire quand le traitement présente un <b>risque élevé</b> .                        |
| <b>DPO</b>                                      | Obligatoire pour le secteur public, le suivi à grande échelle, ou les données sensibles à grande échelle. |
| <b>Privacy by design / by default</b> (art. 25) | Protection intégrée dès la conception et par défaut.                                                      |
| <b>Registre des traitements</b> (art. 30)       | Inventaire documenté de tous les traitements.                                                             |

## LA CHRONOLOGIE D'UNE VIOLATION DE DONNÉES



Figure 4.1 — La règle des 72 heures : le délai court à partir de la connaissance de la violation, pas de sa survenue.

**CHIFFRES À RETENIR**

Sanctions : jusqu'à **20 M€** ou **4 % du chiffre d'affaires annuel mondial** (le plus élevé des deux). Notification à la **CNIL sous 72 h** après en avoir eu connaissance, et information des personnes concernées sans délai si le risque pour elles est élevé. En France, le RGPD est complété par la **loi Informatique et Libertés**.

**NIS2 — sécurité des réseaux et systèmes**

Directive européenne (2022) qui **élargit fortement** le champ de NIS1 : davantage de secteurs, et deux catégories d'entités — **essentielles (EE)** et **importantes (EI)**. Elle impose une gestion des risques, des mesures techniques et organisationnelles, la **gestion du risque de la chaîne d'approvisionnement**, la notification d'incidents, et la **responsabilisation des dirigeants** (sanctions personnelles possibles). Elle se transpose dans le droit de chaque État membre ; en France, l'**ANSSI** est l'autorité de référence.

**DORA — résilience opérationnelle numérique (finance)**

Règlement UE (applicable depuis **janvier 2025**) ciblant le **secteur financier**. Piliers : gestion du risque TIC, gestion et notification des incidents, **tests de résilience** (dont exercices de type red team / TLPT), encadrement du **risque lié aux prestataires TIC tiers**, et partage d'informations sur les menaces.

**ANSSI, LPM et écosystème français**

|                                |                                                                                                              |
|--------------------------------|--------------------------------------------------------------------------------------------------------------|
| <b>ANSSI</b>                   | Autorité nationale française : publie EBIOS RM, le guide d'hygiène, les référentiels et qualifications.      |
| <b>LPM</b>                     | Loi de Programmation Militaire : impose des règles cyber aux <b>OIV</b> (Opérateurs d'Importance Vitale).    |
| <b>OSE / FSN</b>               | Opérateurs de Services Essentiels / Fournisseurs de Services Numériques (issus de NIS1).                     |
| <b>SecNumCloud</b>             | Visa ANSSI qualifiant les offres cloud de confiance.                                                         |
| <b>CSPN / visa de sécurité</b> | Certification / qualification ANSSI de produits de sécurité.                                                 |
| <b>HDS</b>                     | Hébergement de Données de Santé : certification obligatoire en France — <b>essentiel pour une clinique</b> . |

## 4.4 Réglementations sectorielles & comparatif

| Réf.                  | Domaine                      | Points clés                                                                                                                                                                                                                                              |
|-----------------------|------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>PCI-DSS</b> (v4.0) | Cartes de paiement           | Standard imposé par contrat (pas une loi) : <b>12 exigences</b> autour de 6 objectifs. Obligatoire pour qui stocke, traite ou transmet des données de porteurs de cartes.                                                                                |
| <b>SOC 2</b>          | Prestataires SaaS / cloud    | Rapport d'attestation (AICPA) sur les <b>Trust Services Criteria</b> : Sécurité (obligatoire), Disponibilité, Intégrité de traitement, Confidentialité, Vie privée. <b>Type I</b> = conception à un instant ; <b>Type II</b> = efficacité sur 6-12 mois. |
| <b>HIPAA</b>          | Santé (US)                   | Protège les données de santé (PHI) : Privacy Rule, Security Rule, Breach Notification.                                                                                                                                                                   |
| <b>SOX</b>            | Finance (sociétés cotées US) | Sarbanes-Oxley : fiabilité du reporting financier et contrôle interne (s'appuie sur COSO). Sections 302 & 404.                                                                                                                                           |

### Quand mobilise-t-on quoi ? (vue de synthèse)

| Besoin                                              | Référentiel adapté                            |
|-----------------------------------------------------|-----------------------------------------------|
| Structurer et <b>certifier</b> sa sécurité          | ISO/IEC 27001 (+ 27002 pour la mise en œuvre) |
| <b>S'auto-évaluer</b> et communiquer par fonctions  | NIST CSF 2.0                                  |
| <b>Gouverner l'IT</b> et aligner sur le métier      | COBIT                                         |
| Une <b>liste concrète</b> de mesures prioritaires   | CIS Controls v8 / NIST 800-53                 |
| Analyser le <b>risque</b> (France / secteur public) | EBIOS Risk Manager                            |
| Protéger les <b>données personnelles</b>            | RGPD (+ ISO 27701)                            |
| Rassurer un <b>client SaaS</b>                      | SOC 2 Type II                                 |
| Traiter des <b>paiements par carte</b>              | PCI-DSS                                       |
| Opérer un <b>service essentiel / vital</b> (UE/FR)  | NIS2 / LPM (OIV)                              |

## 5 Concepts transversaux indispensables

Le GRC ne vit pas isolé : il s'appuie sur des notions techniques et opérationnelles qu'il faut savoir situer. En voici l'essentiel, expliqué et relié aux trois piliers.

### 5.1 Continuité & reprise (PCA / PRA)

La disponibilité (le « D » de DICP) se joue ici. On distingue **maintenir** l'activité pendant la crise et **restaurer** le SI après.

|                  |                                                                                                                                        |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| <b>PCA / BCP</b> | Plan de Continuité d'Activité : garder les activités critiques en marche <i>pendant</i> le sinistre (organisation, moyens de secours). |
| <b>PRA / DRP</b> | Plan de Reprise d'Activité : restaurer le SI <i>après</i> le sinistre.                                                                 |
| <b>BIA</b>       | Business Impact Analysis : identifie les activités critiques et leurs besoins (dont RTO/RPO). C'est le point de départ.                |
| <b>RTO</b>       | Recovery Time Objective : durée <b>maximale d'interruption</b> tolérée.                                                                |
| <b>RPO</b>       | Recovery Point Objective : <b>quantité de données</b> qu'on accepte de perdre → dicte la fréquence des sauvegardes.                    |



Figure 5.1 — RTO vs RPO : le RPO regarde en arrière (données perdues), le RTO regarde en avant (temps d'indisponibilité).

#### POINT DE CONFUSION FRÉQUENT

Ne jamais inverser : le **RPO** est une quantité de **données** (donc une fréquence de sauvegarde), le **RTO** est un **temps** de remise en service. Un RPO d'une heure impose des sauvegardes au moins horaires ; un RTO de deux heures impose des moyens de reprise capables de tenir ce délai.

### 5.2 Gestion des incidents (NIST SP 800-61)

Malgré la prévention, des incidents surviennent. Un processus mûr réduit leur impact et, surtout, **capitalise** pour la fois suivante (retour à la fonction Govern/Respond/Recover du CSF).

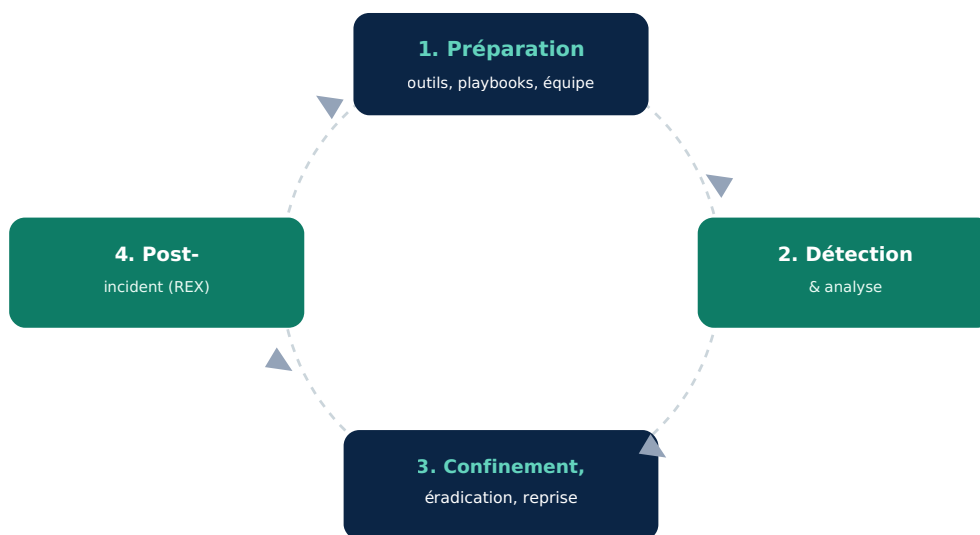


Figure 5.2 — Le cycle de réponse à incident : il boucle, car chaque « post-incident » nourrit la « préparation » suivante.

Notions liées : **CSIRT / CERT** (l'équipe), **playbook** (le mode d'emploi d'un type d'incident), **chaîne de preuve** (forensic), **SLA** de réponse.

## 5.3 Identités & accès (IAM) et Zero Trust

|                                  |                                                                                                                                           |
|----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| <b>AAA</b>                       | Authentication (qui es-tu ?), Authorization (as-tu le droit ?), Accounting (trace de ce que tu fais).                                     |
| <b>MFA</b>                       | Authentification multifacteur : combiner savoir (mot de passe), avoir (téléphone), être (biométrie).                                      |
| <b>SSO</b>                       | Authentification unique (SAML, OIDC).                                                                                                     |
| <b>RBAC / ABAC</b>               | Contrôle d'accès par <b>rôle</b> / par <b>attributs</b> (contexte).                                                                       |
| <b>PAM</b>                       | Gestion renforcée des comptes à privilèges (administrateurs).                                                                             |
| <b>Recertification des accès</b> | Revue périodique des droits pour éviter l'accumulation.                                                                                   |
| <b>Zero Trust</b>                | « Ne jamais faire confiance, toujours vérifier » : plus de confiance implicite liée au réseau, vérification continue, micro-segmentation. |

## 5.4 Classification & protection des données

On **classe** les données (public / interne / confidentiel / secret) pour appliquer des protections proportionnées — c'est le propriétaire (§1.2) qui décide. Notions clés : **chiffrement** au repos et en transit, **gestion des clés** (KMS/HSM), **DLP** (prévention des fuites), et la distinction **pseudonymisation vs anonymisation** — l'anonymisation (irréversible) sort du champ du RGPD, la pseudonymisation (réversible) non.

## 5.5 Détection, menaces & vulnérabilités

|                          |                                                                                                                          |
|--------------------------|--------------------------------------------------------------------------------------------------------------------------|
| <b>SOC / SIEM / SOAR</b> | Équipe de supervision / corrélation des logs / orchestration et automatisation de la réponse.                            |
| <b>EDR / XDR</b>         | Détection et réponse sur les postes et au-delà.                                                                          |
| <b>STRIDE</b>            | Modèle de menaces : Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege. |
| <b>CVE / CVSS</b>        | Identifiant d'une vulnérabilité publique / score de sévérité de 0 à 10.                                                  |
| <b>OWASP Top 10</b>      | Principaux risques des applications web.                                                                                 |
| <b>MITRE ATT&amp;CK</b>  | Matrice des techniques adverses, utile en détection et en scénarios de risque.                                           |

### TON ATOUT PERSONNEL — RELIER LE FORMEL AU GRC

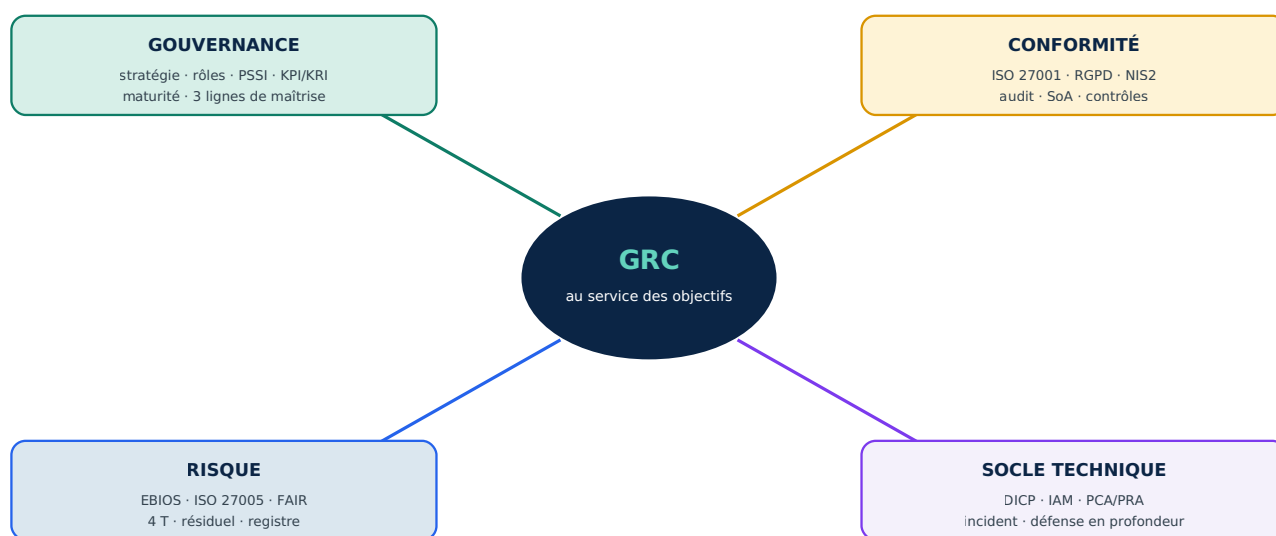
Ton profil FSI (Frama-C/EVA, ProVerif, reverse, CTF) éclaire un angle que peu de spécialistes GRC maîtrisent : la **preuve**. Là où une politique *exige* l'intégrité d'un composant critique, la vérification formelle permet de *la démontrer* (analyse statique pour un programme C, ProVerif pour un protocole). Autrement dit, tu peux transformer une exigence de gouvernance abstraite en garantie technique vérifiable — c'est le niveau de maîtrise le plus élevé du lien entre les trois piliers et la réalité du terrain.

## 6

# Synthèse : relier toutes les notions

Maîtriser le GRC, ce n'est pas connaître chaque notion isolément, c'est voir comment elles s'emboîtent. Cette partie fait le liant : une carte d'ensemble, un fil rouge concret, et la liste des confusions à éviter.

## 6.1 La carte d'ensemble



*Les trois piliers pilotent ; le socle technique exécute. Tout converge vers les objectifs.*

Figure 6.1 — Carte de synthèse : où ranger chaque notion du manuel.

## 6.2 Le fil rouge : un cas de bout en bout

Suivons une seule décision à travers les trois piliers, pour voir la mécanique en action. Contexte : **une clinique veut ouvrir un portail patient en ligne.**

| Étape                      | Ce qui se passe                                                                                                                                                                                                                                                                                             |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Gouvernance décide</b>  | La direction juge la donnée de santé <i>critique</i> , nomme un propriétaire (responsable médical) et un DPO, et inscrit le projet dans la PSSI. Elle fixe une appétence au risque faible sur la confidentialité.                                                                                           |
| <b>Le risque priorise</b>  | Une analyse EBIOS RM identifie l'événement redouté « fuite des dossiers ». Scénario majeur : compromission via l'hébergeur (écosystème) ou un admin hameçonné. Vraisemblance « possible », impact « critique » → risque <b>élevé</b> , au-dessus du seuil.                                                  |
| <b>Traitement</b>          | On <i>réduit</i> : MFA obligatoire, chiffrement au repos et en transit, segmentation, sauvegardes immuables, journalisation ; on <i>transfère</i> partiellement via cyber-assurance ; on <i>surveille</i> l'hébergeur (TPRM). Le risque résiduel devient « moyen » → accepté formellement par la direction. |
| <b>La conformité borne</b> | Le RGPD impose une base légale, une AIPD (donnée sensible), la minimisation et le registre. L'hébergement doit être <b>certifié HDS</b> . On vise ISO 27001 : les contrôles retenus sont tracés dans le <b>SoA</b> , et un audit vérifiera les preuves.                                                     |
| <b>La boucle</b>           | Six mois plus tard, un KRI (tentatives d'accès anormales) monte. On réévalue le risque, on renforce la détection, on met à jour le registre et la PSSI. <b>Le cycle recommence.</b>                                                                                                                         |

#### CE QUE CE FIL ROUGE DÉMONTRE

Aucun pilier ne suffit seul. La **gouvernance** sans risque protège au hasard ; le **risque** sans gouvernance ne décide de rien ; la **conformité** sans les deux coche des cases sans réduire la menace réelle. C'est leur **articulation en boucle** qui produit une sécurité pilotée. Si tu sais raconter ce fil rouge, tu as compris le GRC.

## 6.3 Les points de confusion fréquents (récapitulatif)

| Ne pas confondre                        | La bonne distinction                                                                            |
|-----------------------------------------|-------------------------------------------------------------------------------------------------|
| Gouvernance / management                | La gouvernance <b>oriente et surveille</b> ; le management <b>exécute</b> .                     |
| Propriétaire / dépositaire              | Le propriétaire (métier) <b>décide</b> ; le dépositaire (IT) <b>met en œuvre</b> .              |
| Standard / guideline                    | Le standard est <b>obligatoire</b> ; la guideline est une <b>recommandation</b> .               |
| Menace / vulnérabilité                  | La menace est la <b>cause</b> ; la vulnérabilité est la <b>faiblesse exploitée</b> .            |
| Risque inhérent / résiduel              | Avant contrôles / <b>après</b> contrôles.                                                       |
| Analyse / appréciation du risque        | L'analyse <b>estime</b> ; l'appréciation englobe identification + analyse + évaluation.         |
| Conformité / sécurité                   | La conformité est un <b>plancher</b> ; elle ne garantit pas la sécurité réelle.                 |
| Certification / attestation             | Certification = certificat d'un organisme accrédité ; attestation = rapport d'un tiers (SOC 2). |
| ISO 27001 / 27002                       | 27001 = exigences <b>certifiables</b> ; 27002 = <b>guide</b> de mise en œuvre.                  |
| RTO / RPO                               | RTO = <b>temps</b> de reprise ; RPO = <b>données</b> perdables.                                 |
| Transférer le risque / s'en débarrasser | On transfère l'impact financier, <b>jamais la responsabilité</b> .                              |
| Anonymisation / pseudonymisation        | Anonymisation irréversible (hors RGPD) ; pseudonymisation réversible (RGPD s'applique).         |

## 7

# Cas pratiques & exercices corrigés

On ne maîtrise vraiment que ce que l'on sait appliquer. Traite chaque exercice **sans regarder le corrigé**, puis compare. L'objectif n'est pas la « bonne réponse » unique, mais le bon **raisonnement**.

## EXERCICE 1 — QUALIFIER UN INCIDENT

Un attaquant modifie discrètement des résultats d'analyses médicales dans la base, sans les voler ni couper le service. Quel critère de sécurité est atteint ? Quel type de contrôle aurait le mieux prévenu, détecté, puis corrigé cela ?

### CORRIGÉ 1

Critère atteint : l'**intégrité** (donnée altérée sans autorisation ; ni confidentialité ni disponibilité ici). **Préventif** : contrôle d'accès strict + validation des entrées + signature/hachage des enregistrements. **Détectif** : journalisation intègre + alerte sur modification anormale (SIEM). **Correctif** : restauration depuis une sauvegarde antérieure vérifiée. On voit que la parade combine plusieurs fonctions : c'est la défense en profondeur.

## EXERCICE 2 — CALCUL DE RISQUE QUANTITATIF

Un serveur de facturation vaut 80 000 €. Une panne majeure en détruirait la moitié de la valeur, et l'on estime un tel sinistre tous les 5 ans. Calcule le SLE puis l'ALE. Une solution de redondance à 4 000 €/an ramènerait l'ARO à 1 tous les 20 ans : est-elle rentable ?

### CORRIGÉ 2

$EF = 0,5 \rightarrow SLE = 80\,000 \times 0,5 = 40\,000 \text{ €}$ .  $ARO = 1/5 = 0,2 \rightarrow ALE_0 = 40\,000 \times 0,2 = 8\,000 \text{ €/an}$ . Avec redondance :  $ARO = 1/20 = 0,05 \rightarrow ALE_1 = 40\,000 \times 0,05 = 2\,000 \text{ €/an}$ .  $ROSI = (8\,000 - 2\,000 - 4\,000) / 4\,000 = 0,5 \rightarrow +50 \%$ . La mesure est rentable (elle « rapporte » 50 % de son coût en pertes évitées), donc on peut la recommander avec un argument chiffré à la direction.

## EXERCICE 3 — CHOISIR UNE STRATÉGIE DE TRAITEMENT

Pour chacun de ces risques, propose la stratégie des « 4 T » la plus adaptée et justifie : (a) risque juridique lié à une fonctionnalité expérimentale non essentielle ; (b) risque d'interruption majeure difficile à éliminer entièrement ; (c) risque faible dont la correction coûterait plus cher que l'impact.

### CORRIGÉ 3

(a) **Éviter** : la fonctionnalité n'étant pas essentielle, on la retire — on supprime la source du risque. (b) **Réduire + Transférer** : on abaisse la vraisemblance/impact par des mesures (redondance, PRA) et on transfère le reliquat financier via une assurance. (c) **Accepter** : le coût du contrôle dépasse l'impact ; on assume, mais avec une **validation formelle** et une inscription au registre. La leçon : la stratégie se choisit en comparant coût du contrôle et niveau de risque, dans le cadre de l'appétence.

**EXERCICE 4 — PROPRIÉTAIRE OU DÉPOSITAIRE ?**

Dans une clinique : (a) la chef de service décide que seuls les médecins traitants voient un dossier ; (b) l'équipe infrastructure chiffre la base et applique les droits ; (c) le patient demande l'effacement de ses données. Qui agit à chaque étape, et quel texte régit (c) ?

**CORRIGÉ 4**

(a) **Propriétaire** (métier) : il décide de la classification et des accès. (b) **Dépositaire** (IT) : il met en œuvre la protection décidée. (c) C'est un **droit à l'effacement** du **RGPD** ; le traitement relève du responsable de traitement, avec conseil du DPO. À noter : sur des données de santé, des obligations légales de conservation peuvent limiter cet effacement — d'où l'importance de l'analyse au cas par cas.

**EXERCICE 5 — LIRE UNE SITUATION DE CONFORMITÉ**

Une startup SaaS affirme à un client : « Nous sommes certifiés SOC 2, donc nous sommes sécurisés et conformes au RGPD. » Repère les trois imprécisions.

**CORRIGÉ 5**

(1) SOC 2 est une **attestation**, pas une « certification » au sens strict. (2) Être attesté SOC 2 ne signifie pas « sécurisé » : c'est un socle vérifié à un instant (Type I) ou sur une période (Type II), pas une garantie d'absence de faille — **conformité ≠ sécurité**. (3) SOC 2 (référentiel américain sur des critères de service) ne vaut **pas** conformité RGPD : ce sont deux référentiels distincts. Bonne question à poser : « Type I ou Type II ? » et « quel périmètre ? ».

**EXERCICE 6 — CONTINUITÉ**

Une activité critique exige de ne pas perdre plus de 15 minutes de données et de redémarrer en moins d'une heure. Traduis ces besoins en RTO/RPO et déduis-en deux exigences techniques concrètes.

**CORRIGÉ 6**

**RPO = 15 min** → il faut des sauvegardes/répliques au moins toutes les 15 minutes (voire une réplique quasi continue). **RTO = 1 h** → il faut des moyens de reprise (bascule automatisée, site de secours ou infrastructure de restauration rapide) capables de rétablir le service en moins d'une heure, testés régulièrement via le PRA. Ces besoins proviennent du **BIA**, réalisé en amont.

**EXERCICE 7 — CARTOGRAPHIER AVEC EBIOS RM**

Sur le portail patient, énonce en une phrase ce que produit chacun des 5 ateliers EBIOS RM.

**CORRIGÉ 7**

(1) **Cadrage** : périmètre + valeurs métier (confidentialité des dossiers) + socle (RGPD/HDS). (2) **Sources de risque** : cybercriminel revendeur de données, salarié malveillant. (3) **Scénarios stratégiques** : attaque via l'hébergeur ou un module tiers. (4) **Scénarios opérationnels** : hameçonnage → élévation → exfiltration. (5) **Traitement** : MFA, chiffrement, segmentation, surveillance du tiers, et décision sur le risque résiduel.

**EXERCICE 8 — RELIER LES PILIERS**

Explique, en trois phrases, comment une simple exigence de gouvernance (« les accès doivent être maîtrisés ») se décline dans le risque, la conformité et la technique.

**CORRIGÉ 8**

**Gouvernance** : la PSSI pose le principe de moindre privilège et nomme des propriétaires d'actifs.

**Risque** : l'analyse montre qu'un accès trop large augmente la vraisemblance d'une fuite → on priorise le durcissement des accès à privilèges. **Conformité + technique** : le RGPD (minimisation) et ISO 27001 (contrôles d'accès de l'Annexe A) l'exigent ; concrètement on met en place RBAC, MFA, PAM et une recertification périodique — le tout tracé dans le SoA et vérifié en audit.

# Glossaire & pour aller plus loin

## 8.1 Glossaire des acronymes

**AAA** — Authentication, Authorization, Accounting.

**AIPD / DPIA / PIA** — Analyse d'Impact relative à la Protection des Données.

**ALE** — Annualized Loss Expectancy (perte annualisée attendue).

**ANSSI** — Agence Nationale de la Sécurité des SI (FR).

**ARO** — Annualized Rate of Occurrence (fréquence annuelle).

**ATT&CK** — Base MITRE des tactiques/techniques adverses.

**BIA** — Business Impact Analysis (analyse d'impact métier).

**CIA / DICP** — Confidentialité, Intégrité, Disponibilité (+ Preuve).

**CISO / RSSI** — Responsable de la Sécurité des SI.

**CMMI** — Modèle de maturité (niveaux 0 à 5).

**CNIL** — Autorité française de protection des données.

**COBIT** — Framework de gouvernance de l'IT (ISACA).

**COSO** — Cadre de contrôle interne & ERM.

**CSF** — Cybersecurity Framework (NIST).

**CSIRT / CERT** — Équipe de réponse aux incidents.

**CVE / CVSS** — Identifiant / score de sévérité d'une vulnérabilité.

**DLP** — Data Loss Prevention (prévention des fuites).

**DORA** — Digital Operational Resilience Act (finance UE).

**DPA** — Data Processing Agreement (contrat sous-traitant).

**DPO / DPD** — Délégué à la Protection des Données.

**EBIOS RM** — Méthode d'analyse de risque de l'ANSSI.

**EDM / PBRM** — Evaluate-Direct-Monitor / Plan-Build-Run-Monitor.

**EDR / XDR** — Détection & réponse sur les endpoints.

**EF** — Exposure Factor (facteur d'exposition).

**ERM** — Enterprise Risk Management.

**FAIR** — Méthode quantitative d'analyse de risque.

**GRC** — Governance, Risk & Compliance.

**HDS** — Hébergement de Données de Santé (FR).

**HIPAA** — Loi US sur les données de santé.

**IAM** — Identity and Access Management.

**IRM** — Integrated Risk Management.

**ISMS / SMSI** — Système de Management de la Sécurité de l'Info.

**KPI / KRI** — Indicateur de performance / de risque.

**LPM** — Loi de Programmation Militaire (OIV).

**MFA** — Authentification multifacteur.

**MTD / MTPD** — Durée max d'indisponibilité tolérable.

**NIS2** — Directive UE sécurité des réseaux & systèmes.

**NIST** — National Institute of Standards and Technology (US).

**OIV / OSE** — Opérateurs d'Importance Vitale / de Services Essentiels.

**OWASP** — Fondation sécurité applicative (Top 10).

**PAM** — Privileged Access Management.

**PCA / PRA** — Plan de Continuité / de Reprise d'Activité.

**PCI-DSS** — Standard de sécurité des cartes de paiement.

**PDCA** — Plan-Do-Check-Act (roue de Deming).

**PSSI** — Politique de Sécurité du SI (FR).

**RACI** — Responsible, Accountable, Consulted, Informed.

**RBAC / ABAC** — Contrôle d'accès par rôle / par attributs.

**RGPD / GDPR** — Règlement Général sur la Protection des Données.

**RMF** — Risk Management Framework (NIST 800-37).

**ROSI** — Return On Security Investment.

**RTO / RPO** — Recovery Time / Point Objective.

**SIEM / SOAR** — Corrélation de logs / orchestration de la réponse.

**SLA** — Service Level Agreement.

**SLE** — Single Loss Expectancy (perte par sinistre).

**SoA** — Statement of Applicability (Déclaration d'Applicabilité).

**SoD** — Separation of Duties (séparation des tâches).

**SOC** — Security Operations Center.

**SOC 2** — Rapport d'attestation AICPA (TSC).

**SOX** — Loi Sarbanes-Oxley (reporting financier US).

**SSO** — Single Sign-On.

**STRIDE** — Modèle de menaces applicatives.

**TPRM** — Third-Party Risk Management.

**TSC** — Trust Services Criteria (SOC 2).

**Zero Trust** — « Ne jamais faire confiance, toujours vérifier ».

## 8.2 Sources de référence (pour approfondir)

- **ANSSI** — Guide EBIOS Risk Manager, Guide d'hygiène informatique, référentiels et qualifications ( [cyber.gouv.fr](https://cyber.gouv.fr) / ancien [ssi.gouv.fr](https://ssi.gouv.fr) ).
- **CNIL** — Guides RGPD, modèle de registre des traitements, méthode et logiciel PIA ( [cnil.fr](https://cnil.fr) ).
- **ISO/IEC** — Normes 27001:2022, 27002:2022, 27005, 31000 (organisation ISO).
- **NIST** — Cybersecurity Framework 2.0, SP 800-30, 800-37 (RMF), 800-53, 800-61 (réponse à incident).
- **CIS** — Critical Security Controls v8 et CIS Benchmarks (Center for Internet Security).
- **ISACA** — COBIT 2019 (gouvernance de l'IT d'entreprise).
- **Textes UE** — RGPD (2016/679), directive NIS2 (2022/2555), règlement DORA (2022/2554).
- **OWASP** — Top 10, guides de développement sécurisé ( [owasp.org](https://owasp.org) ).
- **MITRE** — ATT&CK, CVE ( [attack.mitre.org](https://attack.mitre.org) ).

### DERNIER CONSEIL DE MÉTHODE

Relis d'abord la **Partie 0** et la **Partie 6** : elles contiennent la logique qui relie tout. Si tu sais redessiner de mémoire la **boucle GRC**, le **cycle du risque** et la **défense en profondeur**, et raconter le **fil rouge** du portail patient, alors les notions ne « flottent » plus : elles forment un système que tu maîtrises.

— Fin du manuel · Bonne étude, Youssef —